Preliminary Proposal – Secure Hospital IoT Simulation Homelab

Title

Hospital IoT Simulation Homelab for Cybersecurity and Machine Learning Research

Introduction

The increasing reliance on IoT devices and networked medical systems in hospitals has created significant opportunities for improved patient care but also introduces cybersecurity vulnerabilities. This project proposes building a controlled, professional-grade homelab that simulates a hospital IT/OT environment. The purpose is to test data flows, detect anomalies, and evaluate compliance with healthcare cybersecurity regulations such as HIPAA, NIST CSF, Nist 800-53 & 52, IEC 62443, and ISO/IEC 27001.

Problem Statement

Hospitals are highly targeted by ransomware and cyberattacks due to their reliance on patient data and life-critical IoT systems. Real-world testing is dangerous on production systems, yet educational and research environments often lack realistic infrastructure to explore attack surfaces and defenses. This proposal addresses the need for a secure, self-contained lab where students and researchers can safely replicate hospital networks, IoT devices, and regulatory compliance strategies.

Objectives

1. Build a physical and virtualized hospital IT/IoT environment using enterprise-grade equipment.
2. Simulate medical IoT devices (Raspberry Pi sensors for heart rate, temperature, movement, etc.).
3. Develop ML-based anomaly detection to identify patient data irregularities and cyberattacks.
4. Enforce compliance with HIPAA, NIST CSF, IEC 62443, and ISO/IEC 27001 standards.
5. Provide a replicable framework for cybersecurity research and teaching.

Methodology

- Deploy a Dell R740XD server with TrueNAS for storage and VM hosting.
- Segment networks using a UDM SE and UniFi switch with VLANs (IoT, Management, Secure, Guest).

- Connect Raspberry Pi 5s with SenseHats to simulate patient vitals.
- Train ML models on baseline healthy patterns; trigger alerts on anomalies.
- Collect and log all network traffic and attacks for forensic study.
- Conduct compliance mapping to regulatory standards.

Literature Review

- NIST CSF provides structured cybersecurity risk management.
- NIST 800-53&52 outline of OT/IT security and hardening.
- HIPAA mandates PHI protection through encryption and access control.
- IEC 62443 outlines best practices for OT/IoT isolation.
- Recent ransomware attacks on Ohio hospitals highlight urgency (e.g., Kettering Health).

Preliminary Timeline

- Week 1–2: Hardware installation, network configuration.
- Week 3–4: TrueNAS setup, VM provisioning (Kali, Metasploitable, ML nodes).
- Week 5–6: Raspberry Pi sensor integration.
- Week 7–8: Firewalling, VLAN isolation, attack simulation.
- Week 9–10: ML training, anomaly detection, logging.
- Week 11–12: Compliance review, documentation, final testing.

Budget Estimate

- Dell R740XD server: $1,800
- 10× 8TB HDDs: $1,200
- 2× 960GB SSDs: $200
- Raspberry Pi 5 kits ×5: $500
- UniFi UDM SE + Switch + AP: $1,200
- Misc cables, rack, UPS: $500

Total Estimated Cost: ~$5,400

Expected Outcomes

- A fully functional hospital homelab with realistic IoT devices.
- Ability to simulate and detect cyberattacks.
- Machine learning models capable of anomaly detection in patient vitals.
- Documentation of regulatory compliance measures.
- Educational framework for training future cybersecurity professionals.

Stakeholders

- **Doctors** – depend on secure access to electronic patient records.
- **Nurses** – rely on IoT medical devices for accurate real-time monitoring.

- **Patients** – expect confidentiality, integrity, and availability of their medical data.
- **Hospital CEO and Executives** – responsible for regulatory compliance and reputation.
- **IT and Security Personnel** – maintain and defend the hospital network.
- **Clinical Engineers** – oversee medical device integration with the network.
- **Administrative Staff** – handle patient scheduling and billing securely.
- **External Regulators and Auditors** – ensure HIPAA, NIST, IEC 62443, and ISO/IEC 27001 compliance.

Risks and Challenges

- Risk: Misconfiguration leading to uncontrolled data flow.
  Mitigation: Strict VLAN/firewall enforcement.
- Risk: Hardware/software compatibility issues.
  Mitigation: Pre-tested builds, fallback to virtualized equivalents.
- Risk: Scope creep in ML detection models.
  Mitigation: Focus on ECG baseline anomaly detection first.

References

- National Institute of Standards and Technology (NIST) Cybersecurity Framework.
- HIPAA Security Rule, U.S. Department of Health & Human Services.
- IEC 62443 Industrial Cybersecurity Standards.
- ISO/IEC 27001:2013, Information Security Management.
- Case studies: Kettering Health ransomware (2023).

Team Members

Lead: David Moad

- Roles and Responsibilities: Project designer, system integrator, security analyst.
- Qualifications: Computer Engineering student with experience in networking, Linux, and embedded systems.
- Experience: Prior projects in op-amp design, Python scripting, and SDLC analysis (Ultralytics GitHub).